

Gateway, Swagger and Platform Security

Topology

```
Client
-> FinWallet.Gateway :8080
   -> FinWallet.Api :8081
       -> Gateway /providers/bank/*           -> FakeBank.Api :8082
       -> Gateway /providers/fraud/*          -> FakeFraud.Api :8083
       -> Gateway /providers/cutoff/*         -> FakeCutoff.Api :8084
       -> Gateway /providers/campaign/*       -> FakeCampaign.Api :8085
       -> Gateway /providers/communication/* -> FakeCommunication.Api :8086
```

FinWallet does not call provider simulators directly; provider base URLs point back to the Gateway.

Customer authentication boundary

Only register/verify/login/refresh are anonymous at the Gateway. Other /api/* routes require JWT through GatewayAuthenticated. FinWallet.Api independently repeats JWT and business-ownership validation.

Internal provider boundary

FinWallet.Api sends X-Internal-Service-Key to /providers/*. Gateway validates it through InternalService and writes a separate DownstreamServiceKey to the proxied request. Destination business endpoints return 401 without the downstream key.

This creates two separate trust boundaries:

- 1 FinWallet -> Gateway;
- 2 Gateway -> destination.

YARP routing/load balancing

Cluster configuration lives in appsettings. PowerOfTwoChoices, destination addresses, health intervals/timeouts, passive reactivation, max connections and activity timeout can be overridden without source-code changes. Development may use one destination while production can add replicas.

Rate limiting / resource exhaustion

Repository-level controls:

- Gateway per-IP fixed-window rate limit;
- backend second-layer rate limit;
- zero queue by default;
- request body/header-count/header-byte limits;
- request-header/keep-alive timeouts;
- max concurrent connections;
- provider-specific YARP body limits;
- provider HttpClient timeout/connection limits.

These are L7 overload/abuse controls. Volumetric DDoS still requires cloud DDoS protection, L4/L7 load balancing, WAF/CDN/bot protection and network policy.

Swagger

Swagger is shared through FinWallet.Shared.Web across:

- Gateway;

- FinWallet.Api;
- FakeBank;
- FakeFraud;
- FakeCutoff;
- FakeCampaign;
- FakeCommunication.

It is enabled in development and disabled by default in production. Swagger visibility does not bypass endpoint authorization.

Shared HTTP security baseline

- Kestrel Server header off;
- TRACE/CONNECT blocked;
- JSON write-content enforcement;
- correlation ID validation/regeneration;
- Cache-Control: no-store;
- X-Content-Type-Options: nosniff;
- X-Frame-Options: DENY;
- restrictive Referrer/Permissions/Cross-Origin policies;
- CSP;
- CORS allow-list;
- rate limiting;
- request/header/body/connection bounds.

OWASP/API mapping

****Broken Access Control/BOLA:**** Gateway + API JWT, owner-aware SQL, server-derived sub/sid, internal provider credentials.

****Security Misconfiguration:**** production Swagger off, bounded HTTP config, no server header, separate environment config.

****Supply Chain:**** central NuGet versions, explicit packages, CI restore/build/test. SBOM/vulnerability scanning remains open work.

****Cryptography:**** PBKDF2, salts, HMAC OTP, short JWT, secret store, no credential logging.

****Injection:**** parameterized SQL, typed DTOs, no user-controlled SQL fragments.

****Sensitive Business Flows:**** double-entry, durable idempotency, server-side fraud and fail-closed provider behavior.

****Authentication Failures:**** JWT + sessions + refresh rotation + logout + OTP + rate limits.

****Integrity Failures:**** DB constraints, append-only/reversal model and atomic posting.

****Resource Consumption:**** layered rate/body/header/connection/time limits.

****SSRF/Unsafe APIs:**** provider URLs are server-owned configuration and external results remain behind adapters/validation.

Configuration model

Standard .NET precedence:

- 1 appsettings.json;
- 2 appsettings.{Environment}.json;
- 3 environment variables / secret injection;
- 4 explicit providers added later.

Operational values such as network/pool/timeout/rate settings are configurable. Crypto algorithms, double-entry invariants and persistence semantics are not runtime switches.